

From: Johanna Kougbeadjo
Course: Enterprise security (CMAP 685 9080)
Date: 11/09/2025

AI Vendor Risk Management Report

Executive Summary

At our organization, artificial intelligence (AI) capabilities are embedded across analytics, customer operations, and product development functions, as well as within third-party platforms that process sensitive business and client information. While these integrations enhance performance and enable automation, they also increase exposure to specific cybersecurity and compliance risks. When our vendors or subcontractors deploy AI without transparency, fail to meet data protection obligations, or use our data for unauthorized model training, they place our company at risk.

This report provides a framework tailored to our company's AI vendor environment. It focuses on three operational pillars: (1) embedding AI governance and data protection requirements directly into vendor contracts, (2) maintaining a structured vendor risk assessment program to monitor ongoing compliance, and (3) applying NIST-aligned control evaluation criteria to standardize oversight across departments. These actions reflect industry standards, FTC enforcement precedents, and recognized legal expectations that hold organizations fully accountable for the security practices of their service providers (Kosseff, 2022). The framework is designed to help our internal teams (procurement, legal, compliance, and cybersecurity) work in alignment to maintain control, transparency, and assurance throughout all AI-driven partnerships.

1. Contract Clause Recommendations

Within our company, vendor agreements are the primary mechanism for controlling how external partners handle AI systems and the data that flows through them. These contracts form the front line of defense against AI-driven risk by embedding security, privacy, and governance expectations directly into our legal relationships. Each clause is designed to establish clear accountability, define measurable obligations, and mandate transparency throughout the AI lifecycle. The sections below outline specific contractual provisions our organization should require when onboarding or renewing engagements with AI-enabled vendors.

Risk	Proposed Contract Clause	Explanation and Mitigation Rationale
Undisclosed or Opaque AI Use	<i>Vendor must disclose in writing all uses of Artificial Intelligence or Machine Learning systems (including generative, predictive, or decision-support models) that are part of the contracted services. The vendor must detail data sources, model purposes, and operational use cases, and obtain prior written consent before introducing or modifying any AI component.</i>	Transparency is essential for managing algorithmic risk. Lack of visibility into vendor AI activities has been linked to data exposure and compliance violations. In the Blu Products case, the FTC determined that security assurances must extend to third-party practices (Kosseff, 2022). This clause aligns with NIST’s principles of traceability and OECD guidelines on accountability and transparency.
Supply-Chain Vulnerabilities	<i>Vendor must ensure that all subcontractors and third-party providers meet equivalent data protection and security standards. Vendor remains liable for the actions of their subcontractors and must allow the client audit access to verify compliance.</i>	Complex AI ecosystems rely on multiple data handlers and subcontractors. Without adequate controls, a single weak link among our vendors can expose the entire network. The GMR Transcription Services case demonstrated that companies are accountable for their service providers’ failures to encrypt or secure sensitive data (Kosseff, 2022). This clause ensures continuous oversight and aligns with NIST SP 800-161r1’s requirement for tiered supply-chain risk management.
Data Misuse and Unauthorized Model Training	<i>Vendor must not use company data for training, fine-tuning, or improving AI/ML models without written authorization. Upon contract termination, vendor must securely delete all company data and provide certification that no derivative models were trained on that data.</i>	Data misuse is one of the most common and costly AI risks. Organizations risk losing control over proprietary or personal data when vendors use it to train or refine their models. FTC enforcement against Lenovo (2018) illustrated that embedding vulnerable or undisclosed software components constitutes deceptive practice and negligence (Kosseff, 2022). This clause enforces strict ownership and deletion controls, ensuring compliance with GDPR and NIST’s AI RMF “Govern” and “Manage” functions.

Additional Recommendations

To strengthen the above clauses, our company must embed clear operational safeguards within every vendor contract. Each AI vendor agreement will include indemnification terms that assign full financial liability to the vendor for any data breach, misuse, or loss resulting from their systems or personnel. Vendors will be required to submit verified evidence of compliance, such as annual audit reports, vulnerability scans, and penetration test results specific to AI components. The company will also retain the unilateral right to suspend or terminate contracts immediately if vendors fail to disclose AI use or engage in unauthorized data activity. These conditions ensure our organization maintains decisive control over vendor accountability and reduce the risk of operational, legal, or reputational harm while fostering a transparent and enforceable partnership (Michalsons, 2023; Kosseff, 2022).

These measures make AI vendor risk management a core component of our company's operational governance. By implementing the outlined contractual clauses, oversight procedures, and control evaluations, we ensure our organization remains compliant with global regulatory expectations while actively reducing exposure to data misuse, regulatory penalties, and supply chain vulnerabilities (OECD, 2019; NIST, 2023). This integrated approach allows our teams to maintain visibility and authority over all AI-related activities, reinforcing trust with clients, regulators, and partners.

2. Recommended Vendor Assessment Framework

Managing AI risk within our company demands ongoing verification that vendors deliver on the controls and commitments they have agreed to. Our procurement and cybersecurity teams must jointly evaluate whether vendors implement the required safeguards, maintain secure configurations, and follow our AI data protection policies. This process requires periodic reviews, audits, and continuous monitoring of vendors' technical and organizational measures. The assessment framework that follows outlines how our organization will evaluate each vendor's governance structure, risk management processes, and operational maturity to ensure consistent compliance and protection of company data (NIST, 2023; Boyens et al., 2022).

Governance and Oversight

Before any vendor is approved, our company will evaluate its governance and oversight capabilities to ensure alignment with our internal AI management standards and industry principles (OECD, 2019; NIST, 2023). This assessment will be done following three criteria:

- 1. AI System Inventory Transparency:** Vendors must maintain and provide an up-to-date catalog of all AI systems used in service delivery. Each entry should specify the purpose, origin of training data, update frequency, and dependencies on third-party tools or APIs. This gives our teams complete visibility into where and how AI is applied, which will allow us to anticipate potential security or compliance gaps.
- 2. Roles and Accountability Assignment:** Every vendor must have a defined governance structure with designated officers responsible for AI compliance, risk

management, and ethical oversight. These roles must be formally documented. This will ensure that accountability is clear and escalation pathways are known to our internal teams.

3. **Third-Party Assurance:** Vendors are expected to demonstrate that they conduct proper due diligence on their subcontractors and partners. They must verify that downstream entities follow the same security and privacy obligations that we require. The FTC has emphasized that security accountability extends through the full supply chain, not just to direct vendors (Kosseff, 2022; Boyens et al., 2022).

Data Handling and Security Practices

Once governance expectations are confirmed, our company will assess how each vendor handles and secures data within their AI systems according to five criteria:.

1. **Data Usage Controls:** Vendors must provide clear documentation describing how our data is collected, processed, and stored. They must certify that our data is not used for AI training or improvement without written authorization (Michalsons, 2023).
2. **Encryption and Access Controls:** Vendors are required to encrypt all sensitive data during both storage and transmission and implement strong authentication mechanisms to prevent unauthorized access (NIST, 2023).
3. **Audit and Certification:** Vendors must submit evidence of compliance through certifications such as ISO/IEC 27001, SOC 2, or AI governance audits like ISO/IEC 42001. These certifications will be reviewed annually by our compliance team (NIST, 2023).
4. **Incident Response and Notification:** Vendors must maintain documented escalation and containment procedures for AI-related incidents and notify us immediately of any breach or anomaly affecting our data or systems (Kosseff, 2022; NIST, 2023).
5. **Transparency and Disclosure:** Vendors must disclose any embedded AI or software modules that could introduce vulnerabilities, particularly third-party components. This aligns with FTC expectations following the Lenovo enforcement case (Kosseff, 2022) and ensures we can preemptively assess risks before deployment.

Security Evaluation Questions

To ensure that contractual commitments and ongoing assessments are effective, our company will integrate control-based evaluations directly into our vendor oversight process. These evaluations align with the NIST Cybersecurity Supply Chain Risk Management (C-SCRM) framework (Boyens et al., 2022) and translate high-level governance requirements into measurable, operational checkpoints. Each control provides a concrete way to verify whether vendors are managing AI-related risks responsibly and consistently throughout the system lifecycle. This ensures that the standards defined in our contracts and assessment framework

are fully implemented, monitored, and continuously improved across all third-party partnerships.

Evaluation Area	Control Evaluation Question	Objective and Legal Insight	NIST C-SCRM Alignment
AI System Inventory Transparency	Has the vendor provided a comprehensive inventory of all AI systems, their data sources, dependencies, and ownership details?	Supports accurate asset identification and documentation, enabling traceability throughout the supply chain (Boyens et al., 2022; NIST, 2023).	Frame
Roles and Accountability Assignment	Are clear governance structures and responsible officers defined for AI risk management and data security?	Establishes accountability and traceability to ensure consistent decision-making and compliance oversight (NIST, 2023; Boyens et al., 2022).	Assess
Third-Party Assurance	How does the vendor evaluate subcontractors' security practices, and how are those assessments validated?	Ensures downstream supplier integrity and confirms that security obligations extend across the entire supply chain (Kosseff, 2022; Boyens et al., 2022).	Assess
Data Usage Controls	How does the vendor prevent unauthorized use of our company's data for training or AI model optimization?	Verifies data protection compliance, limiting misuse and enforcing contractual boundaries on data access (Michalsons, 2023; NIST, 2023).	Respond
Encryption and Access Controls	Which encryption and access control mechanisms protect sensitive data during transmission, storage, and processing?	Confirms that technical safeguards mitigate confidentiality and integrity risks (Boyens et al., 2022; NIST, 2023).	Respond
Audit and Certification	Does the vendor maintain third-party certifications (e.g., ISO/IEC 27001, SOC	Demonstrates ongoing compliance verification and control maturity across the	Monitor

	2, ISO/IEC 42001), and how often are audits performed?	vendor's ecosystem (NIST, 2023; OECD, 2019).	
Incident Response and Notification	What procedures govern AI-related incident detection, containment, notification timelines, and post-incident analysis?	Validates vendor readiness to detect and respond to disruptions promptly, minimizing operational impact (Kosseff, 2022; NIST, 2023).	Respond
Transparency and Disclosure	How does the vendor disclose vulnerabilities, unapproved AI model changes, or data management flaws impacting service security?	Ensures proactive disclosure and continuous monitoring of integrity issues throughout the AI supply chain (OECD, 2019; Kosseff, 2022).	Monitor

Oversight Practices

Our company will conduct regular vendor risk reviews to confirm that each partner maintains the controls, processes, and documentation required under their contracts (Boyens et al., 2022). These reviews directly support the governance and security standards defined in our contractual clauses and vendor assessment framework. They include validation of compliance reports, results from independent security testing, and follow-up on any identified deficiencies. Vendors will also participate in coordinated tabletop exercises simulating AI-related incidents to evaluate their readiness, communication efficiency, and response coordination with our internal teams (NIST, 2023). Findings from these exercises will feed back into contract negotiations and control evaluations to ensure that lessons learned translate into stronger risk management practices. To maintain a unified view of our vendor landscape, a company-wide risk register will track compliance metrics, remediation progress, and recurring issues for each vendor. This centralized process ties the governance, contractual, and control evaluation components of our AI vendor risk program into a single, continuous oversight cycle.

Conclusion

Our organization is accountable for ensuring that every third-party and subcontractor involved in our AI activities adheres to the same standards of security and transparency as we do. FTC enforcement history, coupled with NIST and ISO guidance, demonstrates that negligence in vendor oversight can result in significant legal and financial penalties as well as brand damage.

By adopting the recommendations in this report, we will reduce our exposure to AI-related risks. These measures will help build a culture of accountability that not only meets current compliance obligations but also accompany our company in its growth.

References

Boyens, J., Smith, A., Bartol, N., Winkler, K., Holbrook, A., & Fallon, M. (2022). *Cybersecurity supply chain risk management practices for systems and organizations* (NIST SP 800-161r1-upd1). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-161r1-upd1>

Kosseff, J. (2022). *Cybersecurity law* (3rd ed.). Wiley.

Michalsons. (2023, January 24). *The AI disclosure clause: Drafting tips for vendor contracts*. <https://www.michalsons.com/blog/the-ai-disclosure-clause-drafting-tips-for-vendor-contracts/63475>

National Institute of Standards and Technology. (2023). *Artificial Intelligence Risk Management Framework (AI RMF 1.0)* (NIST AI 100-1). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.AI.100-1>

Organisation for Economic Co-operation and Development (OECD). (2019). *OECD Principles on Artificial Intelligence*. OECD Legal Instruments. <https://legalinstruments.oecd.org/en/instruments/OECD-LEGAL-0449>